

K-STIG 구축을 위한 LLM 기반 비정형 보안 문서의 SCAP 계열 XML 변환 파이프라인 설계 및 구현

안효빈*, 김이든*, 이동재**

*,** 강원대학교 (학부생, 교수)

Design and Implementation of an LLM-Based Pipeline for Transforming Unstructured Security Documents into SCAP XML for K-STIG Development

HyoBin Ahn*, Yideun Kim*, Dongjae Lee**

*Kangwon National University(Undergraduate student, Assistant Professor)

요약

최근 클라우드 서비스 확산, 공급망 연계 증가, AI 기반 서비스 도입 등으로 보호해야 할 자산의 범위와 위협 환경이 더욱 복잡해지고 있다. 이에 따라 지속적이고 체계적인 보안 점검의 중요성이 커지고 있다. 미국은 보안 설정 가이드인 STIG와 자동 점검 도구 SCAP을 통해 자동·수동 보안 점검이 가능한 환경을 갖추고 있다. 반면 국내의 경우 보안 점검 문서가 PDF, HWP 등 비정형 문서 형태로 제공되는 경우가 많아 자동 점검이 어려우며, 점검 과정이 수작업에 의존하게 되어 체계적이고 반복 가능한 보안 점검 환경을 구축하는 데 한계가 있다. 본 논문은 비정형 보안 문서에서 점검 항목을 추출·정제하고, LLM을 활용해 XCCDF, OVAL, OCIL 형식의 SCAP 계열 XML로 변환하는 파이프라인을 제안함으로써, 국내 비정형 보안 문서를 SCAP 호환 보안 콘텐츠로 전환하기 위한 기반을 제시한다.

I. 서론

최근 보안 환경은 클라우드 도입, 원격근무 확산, 공급망 연계, AI 도입 등으로 보호해야 할 자산과 위협의 범위가 점차 복잡해지고 있다. 이에 우선순위 기반으로 지속적인 보안을 관리하는 RMF(Risk Management Framework)의 필요성이 높아지고 있다. 국내에서도 한국형 K-RMF 도입을 위한 다양한 연구와 논의가 진행되고 있다. 미국은 STIG(Security Technical Implementation Guide)와 SCAP(Security Content Automation Protocol) 기반의 자동·수동 보안 점검 환경을 구축하였다. 반대로 국내 보안 문서는 여전히 PDF, HWP 등의 비정형 문서 형태로 축적된 경우가 많아 점검 항목과 판단 기준을 사람이 직접 해석하고 재구성해야 하는 한계가 있다. 따라서 K-RMF를 실질적으로 운영하기 위해서는 비정형 보안 문서를 구

조화된 보안 통제 및 점검 콘텐츠로 변환하는 기술이 필요하다.

본 논문은 국내 비정형 보안 문서에서 보안 점검 항목을 추출·정제하고, LLM을 활용해 XCCDF, OVAL, OCIL 형식의 SCAP 계열 XML로 변환하는 파이프라인을 제안한다. 이를 통해 문서 중심의 보안 기준을 자동 점검 및 재사용이 가능한 구조화 보안 콘텐츠로 전환할 수 있는 가능성을 검토하고, 향후 K-STIG 및 K-RMF 체계에서 활용 가능한 기반을 마련하고자 한다.

II. 배경지식

2.1 SCAP, XCCDF, OVAL, OCIL 정의

SCAP은 보안 설정과 취약점 정보를 표준화하여, 자동 점검과 일관된 결과를 도출하는 명

세 집합이다. XCCDF(Extensible Configuration Checklist Description Format)는 보안 점검 항목과 기준을 구조화된 체크리스트 형태로 정의하는 언어이며, OVAL(Open Vulnerability and Assessment Language)은 해당 항목을 실제 시스템을 대상으로 기술·평가하는 자동 점검 언어이다. OCIL(Open Checklist Interactive Language)은 사용자에게 제시할 질문과 응답 해석 절차를 표현하는 언어로, OVAL만으로 기술하기 어려운 항목의 수동 점검에 활용된다. 즉, XCCDF는 무엇을 점검할 것인지 정의하고, OVAL은 자동화 가능한 항목을 어떻게 점검할 것인지 기술하며, OCIL은 자동화가 어려운 항목을 어떻게 수동으로 점검할 것인지 표현한다. [1][2]

2.2 국내 연구 동향

국내에서는 SCAP·OVAL 기반으로 보안평가 항목을 범주화·분류하여 관리 효율성을 높이는 연구가 수행되었다. 이러한 연구는 주로 이미 작성된 SCAP 콘텐츠나 정리된 평가항목을 재구성하는 데 초점을 두고 있어, 원천 자료인 PDF·HWP 기반 비정형 보안 문서로부터 점검 항목을 직접 추출하고 이를 XCCDF·OVAL XML로 연결하는 문제는 충분히 다루지 못했다. [3][4]

2.3 비정형 보안 문서의 구조화 필요성

국내 보안 문서는 대개 PDF, HWP 등 사람이 읽는 비정형 문서 형태로 제공되어, 자동 점검에 필요한 규칙 및 검사 로직으로 직접 활용하기 어렵다. 비정형 문서는 설명문, 표, 예외 조건, 판단 기준, 조치 방안 등이 혼재되어 있어 별도의 추출·분류·변환 과정이 필요하다. 따라서 K-RMF와 K-STIG 구축을 위해서는 비정형 보안 문서를 기계가 이해할 수 있는 XCCDF·OVAL XML 형식으로 구조화하는 과정이 필요하다.

III. 비정형 보안 문서의 구조화 및 XML 변환 파이프라인

본 논문은 KISA의 「주요정보통신기반시설

기술적 취약점 분석·평가 방법 상세가이드」 PDF 문서를 대상으로 한다. 비정형 문서에서 점검 항목을 추출·정제하고 LLM으로 구조화 후, 품질 게이트와 자동·수동 점검 분기를 거쳐 XCCDF·OVAL·OCIL XML로 변환하는 파이프라인을 제안한다.

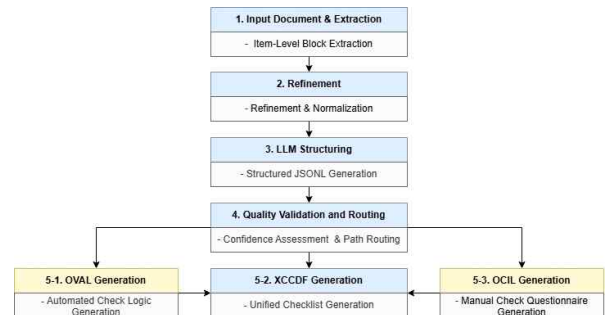


그림 1. 비정형 보안 문서의 구조화 및 XML 생성 파이프라인

3.1 Input Document & Document Extraction

PDF 원문에서 항목 코드 기준으로 문서 블록을 분할하고, 제목 및 본문 정보를 JSON 형식으로 1차 추출하여 후속 정제 단계의 입력으로 활용한다.

3.2 Refinement

1차 추출된 JSON 문서를 후속 구조화가 가능한 형태로 정제한다. 제목의 불필요한 표현을 제거하고, 점검 대상 및 판단 기준 영역을 양호 조건과 취약 조건으로 분리한다. 각 필드에는 상태값과 신뢰도를 함께 기록하여 JSONL 형식으로 저장한다.

3.3 LLM Structuring

2차 정제된 추출 결과를 XML 생성에 활용 가능한 구조화 규칙 형태로 변환한다. 본 실험에서는 OpenAI API의 GPT-4.1-mini 모델을 사용하였다. API는 JSONL 입력의 항목을 읽고, 입력 PDF 원문으로부터 추출·정제된 유사 항목을 참조하여 각 점검 항목의 의미를 해석한다. 예를 들어, “root 계정 원격 직접 접속 금지”와 같은 항목은 점검 대상과 속성을 분리하여 “target: root 계정, attribute: 원격 직접 접속

속 허용 여부”로 재구성한다. 이 과정에서 각 항목은 항목명, 점검 대상, 점검 속성, 비교 연산자, 기준값, 자동 점검 가능 여부, 신뢰도, 설명으로 구성된 구조화 필드로 변환되며, 결과는 항목 단위의 JSONL 형태로 저장된다.

3.4. Quality Validation and Routing

구조화된 결과는 XML 생성에 바로 사용하지 않고, 품질 검증과 분기 과정을 거쳐 자동 점검 및 수동 점검 경로로 구분한다. 먼저 품질 검증 단계에서는 구조화 필드와 false positive 여부, 즉 실제 점검 항목이 아닌데 항목으로 잘못 추출된 오탐 여부를 기준으로 각 항목의 신뢰도를 평가하여 high, medium, low 수준으로 분류한다. 이후 라우팅 단계에서는 자동 점검 가능성과 규칙 복잡도를 기준으로 항목을 oval_ready(자동 점검에 즉시 활용 가능한 항목), oval_complex_review(복합 조건으로 인해 추가 검토가 필요한 항목), xccdf_only(자동 점검이 어려워 XCCDF에만 남는 항목)로 분류한다. xccdf_only와 잔여 항목은 target, attribute, constraints의 구체성과 자동화 가능성 신호를 기준으로 추가 재분류하여 자동 점검 후보와 수동 점검 항목으로 나뉜다.

3.5 Output

최종 출력 단계에서는 구조화 및 분기 결과를 바탕으로 SCAP 계열 XML 산출물을 생성한다. 자동 점검 가능 항목은 XCCDF + OVAL로 연결하여 기계 판정이 가능한 형식으로 변환하고, 수동 점검이 필요한 항목은 XCCDF + OCIL로 연결하여 사람이 직접 확인해야 하는 질문지 형태로 제공한다. xccdf_only와 잔여 항목은 target, attribute, constraints의 구체성과 자동화 가능성 신호를 기준으로 추가 재분류하여, 자동 점검 후보와 수동 점검 항목으로 다시 구분한다. XCCDF는 전체 점검 규칙을 포괄하는 상위 문서이자 공통 인덱스 역할을 수행하며, OVAL은 자동 판정 로직을, OCIL은 수동 검증 항목을 담당한다. 이를 통해 자동화 가능 항목과 수동 검증 항목이 분리된 SCAP 호환 보안 콘텐츠를 생성할 수 있다.

Category	Count	Description
XCCDF Rules	398	Total final checklist items
OVAL-linked Rules	258	Automatically checkable items
OCIL-linked Rules	140	Items requiring manual inspection

표 1. XCCDF/OVAL/OCIL XML 생성 결과

IV. 결론

본 논문은 국내 비정형 보안 문서를 대상으로, 문서 기반 보안 기준을 자동 점검과 수동 점검이 결합된 SCAP 계열 보안 콘텐츠로 전환할 수 있는 기반을 마련하였다. 향후 연구에서는 자동 점검 가능 항목의 비율을 확대하고 수동 점검 문항과 세부 속성 생성의 정확도를 개선하여, K-STIG 및 K-RMF 구축에 활용 가능한 한국형 SCAP 콘텐츠 생성 체계로 고도화할 예정이다.

[참고문헌]

- [1] D. Waltermire, S. Quinn, H. Booth, K. Scarfone and D. Prisaca, The Technical Specification for the Security Content Automation Protocol (SCAP): SCAP Version 1.3, NIST Special Publication 800-126 Revision 3, National Institute of Standards and Technology, April, 2018.
- [2] D. Waltermire, C. Schmidt, K. Scarfone and N. Ziring, Specification for the Extensible Configuration Checklist Description Format (XCCDF) Version 1.2, NIST Interagency Report 7275 Revision 4, National Institute of Standards and Technology, March, 2012.
- [3] 박현경, 안효범, 보안 점검 목록을 효율적으로 관리하기 위한 머신러닝 기반의 보안 점검 항목 분류, 스마트미디어저널, 2022년 12월.
- [4] 김세은, 박현경, 안효범, 국내 보안평가체제에 SCAP을 활용하기 위한 OVAL 정의 분류 연구, 스마트미디어저널, April, 2022.